

PRACTICE / EXPLOIT / LEARN

DVWA LAB

DEVELOPMENTAL WEB APPLICATION
SECURITY LAB



HANDS-ON SECURITY
PRACTICE ENVIRONMENT

Table of contents

1. Executive Summary	3
2. Scope and Authorization	3
3. Methodology	3
4. Finding Summary	3
5. F-001: Reflected Cross-Site Scripting	3
Reproduction summary	3
Evidence	4
6. Impact and Root Cause	4
7. Remediation and Retest	4
8. Limitations and References	4
References	4

1. Executive Summary

The reflected-XSS module was assessed using a controlled, non-destructive web application security testing workflow aligned with the OWASP Web Security Testing Guide. User-controlled input in the name parameter was reflected into the HTML response without context-aware output encoding. A harmless browser-side proof confirmed JavaScript execution in the application origin.

The issue is assessed as **Medium severity in this lab context**. In a real application, exploitability and impact would depend on authentication, affected functionality, data exposure, cookie protections, and the privileges of a victim who opens a crafted link.

2. Scope and Authorization

Testing was performed against an intentionally vulnerable application in a controlled local lab owned and operated for security-learning purposes. The activity was limited to the reflected-XSS functionality and used non-destructive proof techniques.

Excluded activities: public or third-party systems, denial-of-service or destructive actions, credential theft, persistence, data exfiltration, external callbacks, and transmission of lab data.

3. Methodology

The assessment sequence was: confirm authorized scope; establish a baseline; identify the input surface; use a benign proof marker; record behavior and impact; document remediation; and prepare a sanitized publication only after review.

The reporting structure is informed by the OWASP Web Security Testing Guide, NIST SP 800-115, and the OWASP Cross-Site Scripting Prevention Cheat Sheet.

4. Finding Summary

Table 1. Finding summary

ID	Finding	Severity	Status
F-001	Reflected Cross-Site Scripting in the name parameter	Medium	Verified; remediation recommended

5. F-001: Reflected Cross-Site Scripting

The name parameter is reflected into the server-generated HTML response without context-aware output encoding. A benign script marker was interpreted by the browser, demonstrating reflected cross-site scripting.

Classification: CWE-79, Improper Neutralization of Input During Web Page Generation

OWASP mapping: A03:2021 - Injection

Affected component: Reflected-XSS input and response handling

Reproduction summary

Submit a harmless script marker through the reflected-XSS input field and observe whether the returned page treats the marker as executable HTML or JavaScript. The exact payload and internal request details are intentionally omitted from this public document; the working evidence contains the reproducible test record.

Evidence

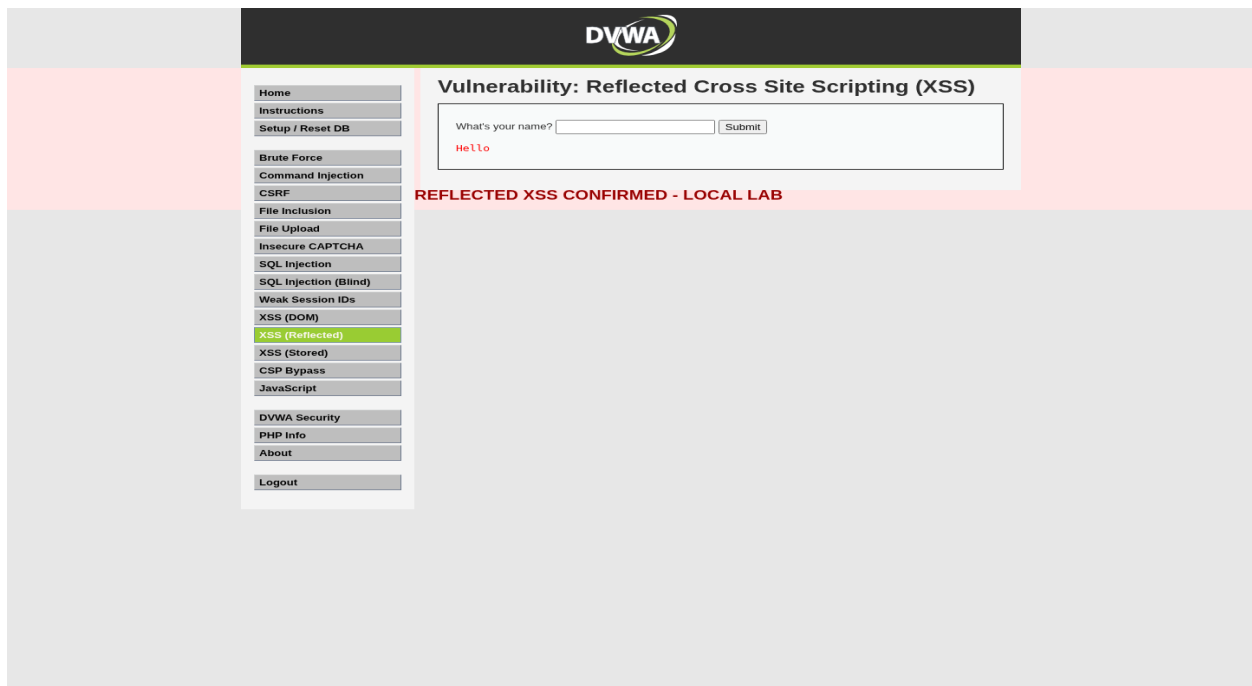


Figure 1. Sanitized browser evidence for the reflected-XSS case study.

6. Impact and Root Cause

If the same behavior existed in a real authenticated application, an attacker could craft a link that executes script in the victim application origin. Depending on functionality and browser protections, consequences could include phishing, page manipulation, unauthorized actions in the victim session, or access to data available to client-side code.

The root cause is insertion of untrusted input into an HTML response without encoding it for the exact output context. Client-side filtering and blacklist-based blocking are not substitutes for correct server-side output handling.

7. Remediation and Retest

Apply context-aware output encoding where untrusted data is written into HTML, attributes, JavaScript, CSS, or URLs. Prefer safe DOM APIs and safe sinks, validate business-format input as an additional control, add regression tests for reflected/stored/DOM XSS, and review Content Security Policy and cookie attributes as defense in depth.

After remediation, the original proof should be inert. Representative output contexts should be tested, before-and-after evidence captured, and the final status recorded with the remediation date and result.

8. Limitations and References

This is a case study from an intentionally vulnerable lab application. It demonstrates assessment and reporting technique; it is not a production penetration-test opinion. The result must not be generalized to another application without validating its code, authentication model, business impact, exposure, and compensating controls. Only the reflected-XSS module is included here.

References

OWASP Web Security Testing Guide
OWASP Cross-Site Scripting Prevention Cheat Sheet
NIST SP 800-115: Technical Guide to Information Security Testing and Assessment
CWE-79: Improper Neutralization of Input During Web Page Generation